

5.2. УПРАВЛЕНИЕ ДОСТУПОМ В СУБД SQL SERVER

Цель работы.

Приобретение практических навыков настройки разрешений на доступ к объектам баз данных в среде СУБД Microsoft SQL Server 2008/2012.

Используемые программные средства.

Компьютер или виртуальная машина с установленной ОС семейства Windows и СУБД SQL Server. При работе в сети возможно совместное использование одного экземпляра SQL Server. В этом случае на остальных компьютерах должны быть установлены только клиентские компоненты и SQL Server Management Studio. Для выполнения работы необходимы права, позволяющие создавать новую базу данных на экземпляре SQL Server.

Теоретические сведения.

Управление разрешениями на объекты реляционной базы данных несколько отличается от аналогичных операций в отношении объектов файловой системы. В данной лабораторной работе на примере СУБД SQL Server эти отличия будут показаны.

При работе с разрешениями в SQL Server используется понятие участников (principals), которые могут запрашивать ресурсы SQL Server, и которым могут предоставляться разрешения на использование таких ресурсов. Выделяются следующие группы участников:

- участники уровня Windows, к которым относятся локальные и доменные учетные записи пользователей и группы;
- участники уровня SQL Server, к которым относятся учетные записи SQL Server и роли уровня сервера;
- участники уровня базы данных — пользователи базы данных и роли уровня базы данных и приложения.

Необходимо отметить, что SQL Server разделяет понятие учетной записи (login) и пользователя (user). Сервер может быть сконфигурирован на использование только аутентификации Windows (*англ.* Windows Authentication Mode, используется по умолчанию) или на использование смешанного режима аутентификации (*англ.* SQL Server and Windows Authentication mode), см. рис. 5.3. В первом случае

login можно создать только для пользователя или группы Windows. Во втором случае также возможно использовать собственные учетные записи SQL Server — логин и пароль хранятся самой СУБД, и ее же средствами выполняется проверка подлинности. При использовании смешанной аутентификации становится доступной административная учетная запись sa, которую рекомендуется переименовать и назначить ей надежный пароль. Учетная запись авторизуется на выполнение одной из серверных ролей (табл. 5.1).

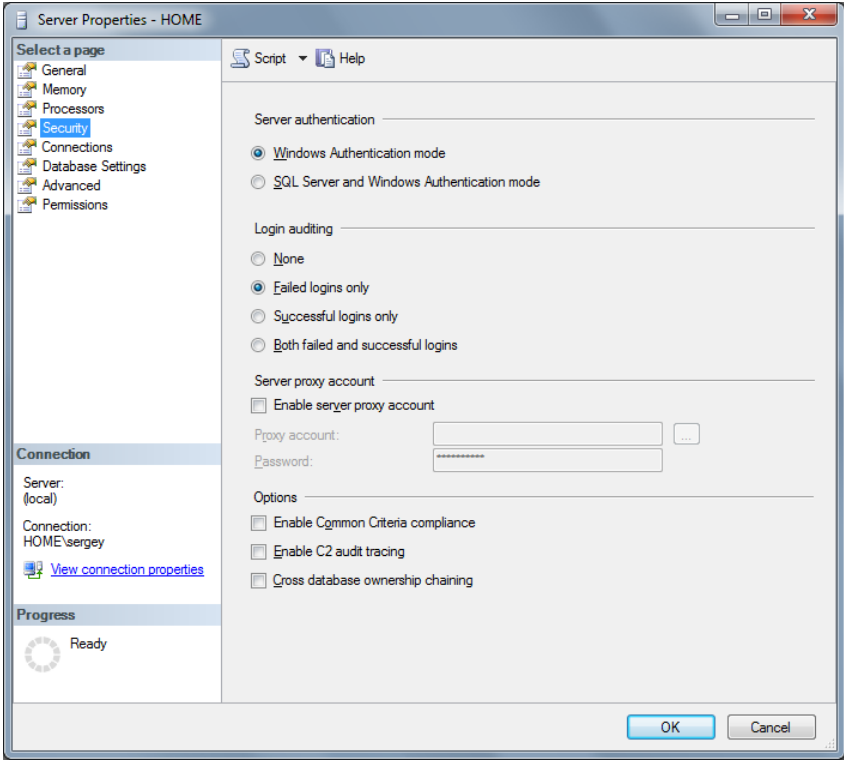


Рис. 5.3. Окно редактирования настроек безопасности экземпляра SQL Server

Таблица 5.1

Роли уровня сервера

Роль	Описание возможностей
sysadmin	Разрешено выполнять любые действия на сервере.
dbcreator	Разрешено создавать базы данных.
bulkadmin	Могут выполнять инструкцию BULK INSERT.
diskadmin	Позволяет управлять файлами на диске.
processadmin	Позволяет управлять подключениями, запускать и приостанавливать экземпляр SQL Server.
securityadmin	Создание и управление учетными записями, право «сбросить» пароль учетной записи. Управление разрешениями на уровне сервера и на уровне базы данных (при наличии доступа к базе данных).

serveradmin	Включает возможности ролей diskadmin и processadmin, позволяет изменять параметры конфигурации на уровне сервера и выключать сервер.
setupadmin	Добавление и удаление связанных серверов.
public	Каждая учетная запись принадлежит этой роли, членство в роли public изменить нельзя.

На уровне базы данных учетной записи сопоставляется пользователь (user). Для одной и той же учетной записи в различных базах данных сервера могут создаваться пользователи с разными именами.

Пользователи получают разрешения на работу с объектами базы данных или напрямую, или путем авторизации пользователя на выполнение одной из ролей уровня базы данных (рис. 5.4). Последний способ является более предпочтительным и позволяет организовать управление доступом в соответствии с ролевой моделью, описанной в первой главе пособия.

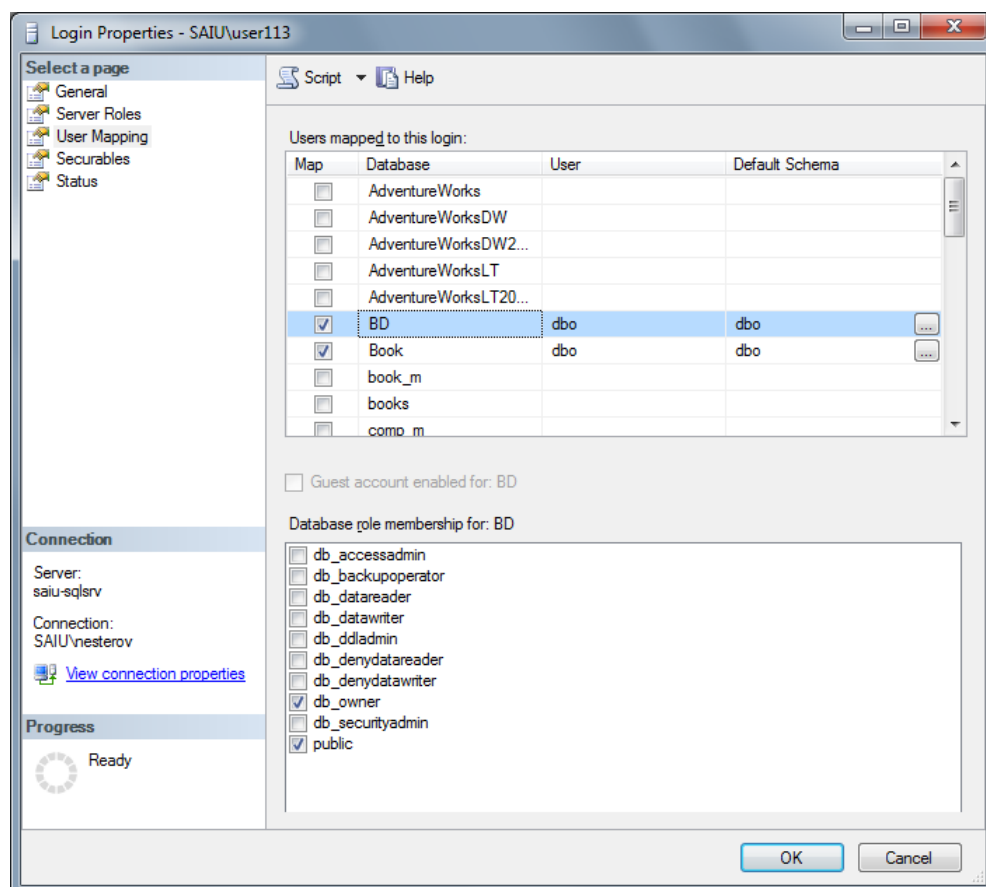


Рис. 5.4. Учетные записи и соответствующие им пользователи и роли в базах данных

Список ролей уровня сервера предопределен, и новые создавать нельзя (табл. 5.1). Также есть предопределенный набор ролей уровня базы данных (табл. 5.2), но в этом случае имеется возможность создавать новые роли.

Таблица 5.2

Роли уровня базы данных

Роль	Описание возможностей
db_owner	Владелец базы данных, можно выполнять все действия по настройке и обслуживанию базы данных, а также удалять базу данных.
db_securityadmin	Управление составом ролей (кроме роли db_owner) и связанными с ними разрешениями.
db_accessadmin	Добавление и удаление пользователей базы данных.
db_backupoperator	Возможность создавать резервные копии базы данных.
db_ddladmin	Выполнение DDL-инструкций (создание, изменение, удаление объектов базы данных, таких как таблицы, представления и т. д.).
db_datareader	Чтение данных (SELECT) из всех пользовательских таблиц, представлений и функций.
db_denydatareader	Запрет на чтение данных (SELECT) из всех пользовательских таблиц, представлений и функций.
db_datawriter	Право добавлять, удалять или изменять данные во всех пользовательских таблицах.
db_denydatawriter	Запрет добавлять, изменять или удалять данные в пользовательских таблицах.
public	Роль по умолчанию, имеющаяся в каждой базе данных. Каждый пользователь БД авторизован на эту роль.

Более подробную информацию об организации системы безопасности СУБД SQL Server можно получить из справочной системы TechNet: <http://technet.microsoft.com/ru-ru/library/bb510589.aspx>.

План работы.

1. Используя указанную преподавателем доменную или локальную учетную запись Windows, с помощью SQL Server Management Studio подключитесь к используемому экземпляру SQL Server. Проверьте установленный на сервере режим аутентификации.

2. В окне Object Explorer (по умолчанию — левая часть окна Management Studio) откройте список учетных записей (logins). На выполнение каких серверных ролей авторизована используемая вами учетная запись?

3. В каких базах данных сервера вашей учетной записи сопоставлены пользователи? На выполнение каких ролей они авторизованы?

4. В среде Management Studio создайте новую базу данных. Откройте список пользователей и ролей. Убедитесь, что учетная запись, под которой вы работаете, сопоставлена пользователю dbo, авторизованному на роль db_owner.

5. Используя приведенный ниже скрипт, создайте в базе данных таблицы. Перед тем как запустить скрипт, уберите символы комментария («--») из первой строки и после ключевого слова use укажите имя вашей базы данных.

```
--use MyTest1
GO
CREATE TABLE dbo.Book (
    book_id int IDENTITY (1, 1) primary key,
    Title varchar(50) NOT NULL, --название книги
    Author varchar(50), -- автор
    Publisher varchar(50), -- издательство
    [Year] smallint) -- год издания
GO
CREATE TABLE dbo.Status (
    Status_id int IDENTITY (1, 1) primary key,
    Status_name varchar(50) NOT NULL
) -- статус: выдана, в библиотеке и т.д.
GO
CREATE SCHEMA libr
GO
CREATE TABLE libr.Book_in_lib (
    lib_id int primary key , --номер экземпляра
    book_id int references dbo.Book ,
    status_id int references dbo.[Status])
GO
```

Обратите внимание, что приведенный скрипт создает не только три таблицы, но и схему `libr`. В SQL Server схема является контейнером логического уровня, к которому относятся объекты базы данных. Во вновь созданной БД уже будет несколько схем: `dbo`, `sys`, `information_schema` и т. д. Схема `dbo` — это схема по умолчанию для новых пользовательских объектов, `sys` и `information_schema` используются системными объектами. Оператором `CREATE SCHEMA` в БД можно создавать новые схемы.

Защищаемым объектом, на действия с которым пользователю предоставляются разрешения, может быть база данных, схема или объект базы данных. Определенное для схемы разрешение неявным образом распространяется на все объекты схемы, разрешение для базы данных — на все схемы и объекты этих схем.

6. Для указанной преподавателем учетной записи SQL Server (при самостоятельном выполнении работы создайте учётную запись Windows и учётную запись SQL Server для нее) создайте пользователя в вашей базе данных, в качестве схемы по умолчанию выберите `dbo`. В Management Studio это можно сделать из графического интерфейса (контекстное меню узла Security для выбранной БД, там New...-> User) или выполнив оператор `CREATE USER`. Например (если схема не указана, подразумевается `dbo`):

```
USE MyTest1
```

```
go
```

```
CREATE USER ns FOR LOGIN [HOME\ns]
```

Добавьте этого пользователя в роль `db_datareader`. Это можно сделать или через графический интерфейс или с помощью системной хранимой процедуры `sp_addrolemember`, первым параметром которой будет имя роли, а вторым — имя пользователя.

```
EXEC sp_addrolemember 'db_datareader', 'ns'
```

Введите в таблицы тестовый набор данных.

Подключитесь к серверу с учетной записью другого пользователя. Убедитесь, что можно получить доступ к базе данных и читать записи из всех таблиц, а добавлять или изменять данные нельзя.

7. Создадим новую роль уровня базы данных и добавим ей разрешение на удаление (DELETE), изменение (UPDATE) и добавление данных (INSERT) в объектах схемы libr. Добавим нашего пользователя к этой роли. Указанные действия надо выполнять с правами администратора или владельца базы данных. Как и в предыдущем случае, все это можно сделать в графическом интерфейсе или запуском скрипта.

```
CREATE ROLE libr_writer
GO
GRANT INSERT, UPDATE, DELETE ON SCHEMA :: libr TO
libr_writer
Go
EXEC sp_addrolemember 'libr_writer', 'ns'
```

Используемый в приведенном скрипте оператор GRANT позволяет предоставить разрешения. Оператор DENY позволяет запретить выполнение каких-то действий, а оператор REVOKE отменяет установленные оператором GRANT или DENY настройки разрешений. Таким образом, у разрешения может быть три состояния: «разрешено», «запрещено», «не задано». Действие можно выполнить, только если оно разрешено непосредственно пользователю или одной из ролей, на которые он авторизован. Запрещение более приоритетно, чем разрешение: если пользователь авторизован на выполнение двух ролей, одной из них действие разрешено, а другой — запрещено, то пользователь это действие выполнить не сможет. В SQL Server Management Studio можно просмотреть эффективные разрешения для пользователя (рис. 5.5).

Конкретный набор возможных разрешений зависит от типа объекта, с полным списком разрешений рекомендуется ознакомиться по справке или приведенной ниже статье TechNet:

<http://technet.microsoft.com/ru-ru/library/ms191291.aspx>.

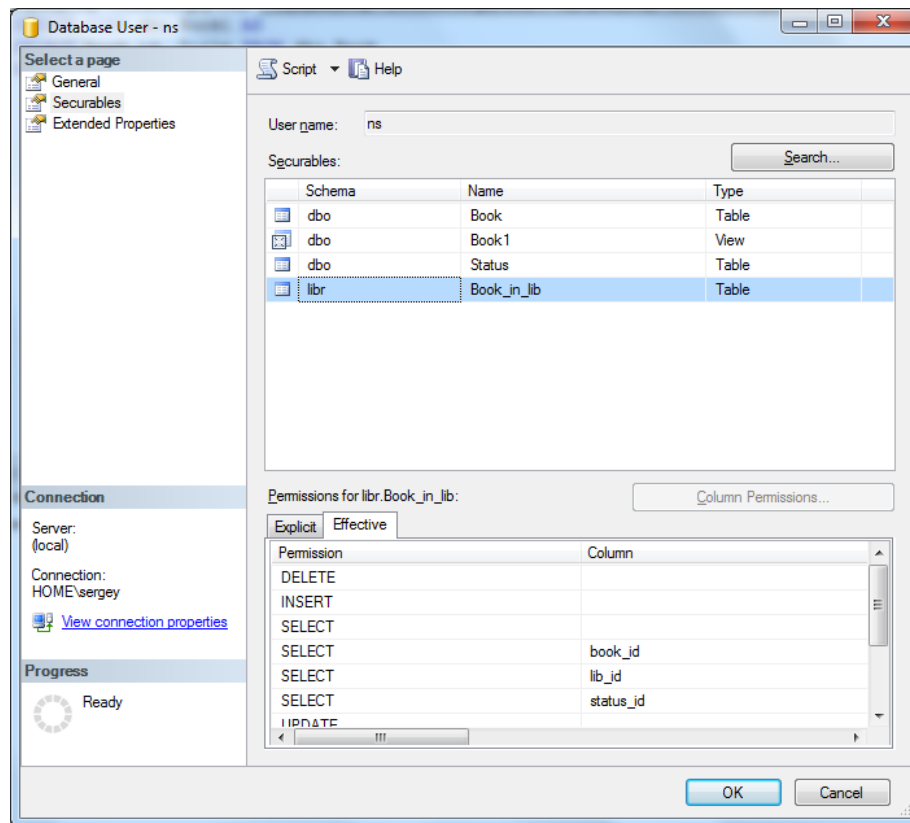


Рис. 5.5. Эффективные разрешения пользователя

Выполните описанные действия. Убедитесь, что пользователь с ограниченными правами может изменять данные в таблице `Book_in_lib`, относящейся к схеме `libr`.

8. Иногда нужно предоставить пользователю права на изменение отдельных столбцов. Как отмечается в документации SQL Server, на столбец могут быть предоставлены только разрешения `SELECT`, `REFERENCES` и `UPDATE`. Например:

```
GRANT UPDATE ON dbo.Book(Title) TO libr_writer
```

Выполните аналогичные действия в своей базе данных, проверьте, что пользователь получил указанные разрешения.

9. Самостоятельно по справке ознакомьтесь с форматом оператора `CREATE VIEW`, особое внимание обратите на задаваемые дополнительные параметры. Создайте представление, выбирающее из таблицы `Book` книги, изданные не ранее 2000 года. Предоставьте пользователю с ограниченными правами возможность изменять и добавлять подобные книги. Возможности изменять прочие записи таблицы и добавлять книги, изданные до 2000 года, он иметь не должен.